

The Board and Risk Lens

An audience-specific reading of the OIA Reference Model for boards of directors, audit and risk committees, and the chief risk officers who support them.

By Mark Templeton · Part of the OIA Lens System · Version 0.5 · 2026 · Published by the Agentics Foundation

This lens is authored to the OIA Lens System methodology (5–7 interpretive lenses across 2–3 orthogonal axes) and is consistent with the Lens System v0.3 overview and the CISO Lens v0.5. Uniquely among the published lenses, it **inverts** the model — treating the seven cross-layer spans as the primary axis of governance interest, with the ten layers as the substrate against which exposure is mapped. The architecture is invariant; the reading changes.

1. What this document is

The OIA Reference Model describes the structural shape of enterprise intelligent systems. It is deliberately vendor-neutral and audience-neutral — ten layers, seven cross-layer spans, three defining properties, four named threat surfaces, written so that any audience can read the same architecture without it being slanted toward any one of them.

Reference architectures in their pure form are read by very few people. Directors and risk officers do not work from structural specifications. They work from fiduciary duty, disclosure obligations, and the frameworks their audit and risk functions are being asked to attest against — with the regimes evolving around them in real time. Without translation, the OIA risks being filed as an engineering artefact that never reaches the governance conversation it was built to inform.

This is the translation. The Board and Risk Lens reads the same OIA architecture through the questions a board is actually asking, the accountability and disclosure frameworks already in their planning, and the spans of exposure that a board must be able to govern without becoming technologists. The architecture is invariant. The lens changes the language — and inverts the reading.

2. What is in the board planning conversation in 2026

Seven observations frame what the governance audience is engaging with today. The lens that follows is calibrated to them.

- **AI reached the board faster than any technology category in recent memory.** Directors comfortable overseeing cloud a decade ago are now accountable for something they understand structurally less well.
- **Disclosure regimes are evolving in real time.** SEC, FCA, and equivalent regimes are pushing toward explicit articulation of material AI risk before the vocabulary has stabilised.
- **The audit committee lacks a structural vocabulary for what to audit.** The auditees are still defining what “good” looks like, and internal audit has no stable architectural anchor.
- **Accountability for agent action is unsettled.** When an agent acts, who answers — the system owner, the model provider, the vendor, or the chief executive?
- **Fiduciary doctrine is being read in light of AI.** Caremark in the United States, and equivalents elsewhere, are being interpreted by the plaintiffs’ bar against AI deployments — governing AI is now a duty, not a courtesy.
- **Resilience to silent change is a new exposure.** A model a business depends on can be changed by its provider, or an agent can act outside its intended scope, with no perimeter event to detect.
- **The board must govern AI, not receive reports about it.** The distinction between oversight and rubber-stamping is precisely what fiduciary duty now turns on.

3. The six interpretive lenses on three axes

The Board and Risk Lens organises how directors and risk officers think about AI as a governance category through six interpretive lenses on three orthogonal axes. The lenses are not new framings the board must learn; they are the accountability frames directors already work from, named and anchored to the frameworks the risk and audit functions already maintain.

Accountability axis · Who answers for AI

AI as Fiduciary Duty. *Govern AI strategy and risk concurrently — do not rubber-stamp it.* The duty of oversight requires a structural basis for asking the right questions of management. Anchor: **Caremark doctrine** (and equivalents).

AI as Disclosure. *Know your material AI risk well enough to disclose it.* Material exposure must be articulable in the layer-and-span terms a regulator and an investor can follow. Anchor: **SEC / FCA disclosure regimes.**

Oversight axis · What the board oversees

AI as Managed Risk. *Hold an integrated view of AI risk across the lifecycle.* No existing risk taxonomy produces this view on its own; the spans supply the connective structure. Anchor: **NIST**

AI Risk Management Framework.

AI as Audited System. *Know what to audit, and where the evidence lives.* Auditability cannot be retrofitted; the architecture must show, layer by layer, where governance evidence physically resides. Anchor: **ISO/IEC 42001**.

Exposure axis · Where the risk concentrates

AI as Regulated System. *Classify high-risk systems correctly and locate human oversight.* Regulatory reach is extraterritorial; the identity span and Layer 9 name where oversight is implemented. Anchor: **EU AI Act**.

AI as Sovereign Exposure. *Govern sovereignty as one integrated concern, not three disconnected ones.* Jurisdictional, operational, and energy sovereignty are a single exposure the board must be able to articulate. Anchor: **Sovereignty span**.

4. The four threat surfaces as governance exposures

The OIA names four threat surfaces of the agentic era as canonical inside the architecture. The board does not defend against them operationally — it must be able to **ask whether management has them under control**, and understand each as a disclosable, insurable, fiduciary exposure.

Mimicry. *“Can management demonstrate that we can tell humans from agents — and real content from synthetic — at every entry point, and have we disclosed the exposure where we cannot?”*

Layer 9. A deepfake-authorized transaction is a board-level loss event.

Agent-in-the-middle. *“Is there governance over the chain between our agents and their tools, or is that trust unmonitored?”* Layer 7. An unmonitored orchestration boundary is an un-auditable one.

Agent spoofing. *“Are agent identities scoped and attestable, so an agent cannot inherit authority we never granted it?”* Identity span, Layers 5–9. The OIA’s named open question — and therefore a live area of residual risk the board should track.

Model compromise. *“Are we resilient if a model we depend on is silently changed, and are we scoring model trust against current reality?”* Layer 5. Dependency on an externally mutable model is a continuity and disclosure exposure.

5. The seven spans through the Board and Risk Lens

Uniquely, this lens reads the model **spans-first**. The cross-layer spans are the primary axis of

governance interest; the ten layers are the substrate against which exposure is mapped. For each span, the board's governing question, the framework anchor, and where in the architecture the exposure concentrates.

Security. *“Is our security posture governed across the whole architecture at machine speed, and where is it weakest?”* Anchor: NIST AI RMF. Widest scope — every layer; a lower-layer weakness that fails to surface upward is the failure mode.

Sovereignty. *“Can we articulate our jurisdictional, operational, and energy sovereignty exposure as one integrated concern?”* Anchor: EU AI Act, Sovereignty. Established at Layer 2, threading upward; only as strong as the weakest layer.

Auditability. *“Can we reconstruct what happened and why — and can we prove it was designed in, not promised for next quarter?”* Anchor: ISO/IEC 42001. Cannot be retrofitted; originates at Layer 3. The observation that makes “we’ll improve auditability later” architecturally untenable.

Identity. *“Do we govern all three actors — humans, agents, and the foundation models themselves — with the accountability each requires?”* Anchor: NIST AI RMF, EU AI Act (human oversight). Concentrates at Layers 7, 9, and 5.

Energy and Environmental Concerns. *“Is our AI energy exposure a governed capital and sustainability concern, or an operational surprise?”* Anchor: disclosure/ESG regimes. Originates at Layer 0; propagates as cost, capacity, and impact.

Provenance. *“Can we trace the lineage of the information, models, decisions, and actions we are accountable for?”* Anchor: NIST AI RMF, EU AI Act. Threads Layer 3 to Layer 9; the property that makes auditability possible.

Verifiability. *“Is our trust in AI operations cryptographically proven, or contractually asserted?”* Anchor: Confidential Computing Consortium. New in v0.5; threads Layers 1, 2, 4, 5, and 8. The board's strongest lever for converting vendor promises into evidence.

Continuity Fabric (Layer 8) — the exception worth naming. Although this lens reads spans-first, Layer 8 recurs across every span as the recovery, rollback, and post-incident-integrity gap. It maps directly to the resilience and disaster-recovery questions risk committees already ask, and is the layer at which “the model that decided is no longer the model deployed” becomes a governable, rather than invisible, exposure.

6. Adopting the lens

The Board and Risk Lens is published as a Foundation reference. Three uses are anticipated.

- **As a governance lens for the board and risk function.** The seven spans provide a

structural vocabulary for oversight, disclosure preparation, and integrated risk views — letting directors ask the right questions of management without becoming technologists.

- **As an audit anchor.** The audit committee can use the spans-over-layers map to locate where governance evidence physically lives, making AI systems auditable against a stable architectural reference rather than a moving target.
- **As a disclosure and accountability vocabulary.** When articulating material AI risk to regulators, investors, and in executive session, the lens gives the board a defensible, structured way to describe exposure layer by layer and span by span.

The Foundation invites the governance community to engage with the lens, push back on what does not fit, and contribute to its continued refinement. The architecture will continue to develop. The Board and Risk Lens will develop with it.